This flexibility makes it an excellent choice for systems where conditions and constraints are as important as identity.

6.2.1 How ABAC works

Let’s explore figure 6.4 more deeply to see how ABAC makes authorization decisions. When Alice and Bob each try to access a sensitive financial document, their requests are routed to an authorization client, which queries a central policy engine. That engine evaluates a policy using attributes from three sources: the principal (Alice or Bob), the resource (the Q2 Financial Data), and the environment (the time, network risk level, and request type). In this example, the policy grants access only if the requesting principal belongs to the same department as the resource owner and has “high” clearance and the request occurs before 6 p.m. Because Alice meets all of these criteria, her request is permitted. Bob, who has “low” clearance, is denied.

This example highlights a key aspect of ABAC: policies are static, but evaluated dynamically based on current attributes. The rules themselves—written in a policy language—don’t change from one request to the next. What changes are the attribute values. Different times, network conditions, or HR system assignments can produce different results. Policies function like code. Attributes serve as their inputs.

In practice, ABAC systems evaluate many policies across a variety of contexts, not just a single one, as shown in figure 6.4. A policy engine might retrieve relevant policies from multiple policy stores—some scoped to an application, and others global to the organization. Attributes are collected from a wide range of systems: identity platforms, HR systems, device management services, resource metadata stores, and environmental sensors. Each request can trigger the evaluation of multiple policies, each containing fine-grained logic to match a wide range of conditions.

In real-life systems, deciding whether to grant access can involve evaluating dozens of policies for a single request. Policies can be layered: some might establish baseline requirements—such as device management or geo-fencing—while others relate to specific actions, departments, or sensitivity levels.